Mandatory 1 - Anvendt Kryptografi

Mads Lindersson - Mali0002

Valg af opgave: Clients - server løsning

Hvordan bruger du applikationen

Stå i mappen mads_lindersson_mandatory_1.
Kør server.py med kommandoen: *python server.py*.
Åben en ny terminal.
Kør client.py med kommandoen: *python client.py*.
Følg instruktionerne i terminalen.
Beskeder fra client1 vises på serverens terminal.

Kryptografisk Implementation

Der andvendes KDF'en Bcrypt til at udføre hashing i applikationen. Bcrypt er utroligt godt til hashing af passwords da den er være meget svær at bryde, og derfor ikke feasible for en ondsindet part. Så længe der bliver brugt 8 characters og minimum 3 klasser af tegn på et password, så vil det tage for lang tid at brute force Bcrypt hashes.
Source: https://specopssoft.com/blog/hashing-algorithm-cracking-bcrypt-passwords/

Hashet gemmes hardcoded i en dictionary på serveren, så altså gemmes det in memory og er ikke særligt sikkert.

```
accounts = {"client1": '$2b$16$u6ICB8a/Iu8WuXvacZMXq.EVbxWnhM/SJCjHOXstjw4sB4VJsNwa6'}
```

Men da der var en begrænsning på antal af filer der måtte laves, var dette en nødvendig løsning.

Klienten sender password i klartekst, og dermed ukrypteret, til serveren. Dette er nødvendigt da klienten ikke kan hashe grundet salt. der genereres en ny salt for hver gang der hashes, og dermed vil hash værdien være en anden end den på serveren.

```
json_login = {
    "username": username,
    "password": password
}

json_message = json.dumps(json_login).encode("utf-8")
clientsocket.sendall(json_message)
```

Serveren validere det fulde login, passworded bliver hashet på serveren og derefter sammenlignet med det hash som er gemt på serveren.

```python
def validateLogin(request):
    loginCred = unpackRequestToLogin(request)

    if loginCred[0] not in accounts:
        return [False, None]

    if bcrypt.checkpw(loginCred[1].encode("utf-8"), accounts[loginCred[0]].encode("utf-8")):
        return [True, loginCred[0]]
    else:
        return [False, None]
```

Wireshark capture

Det kan ses i Wireshark at der sker et TCP handshake og derefter bliver der sendt noget data, der nemt kan læses. Dataen indeholder username og password.

